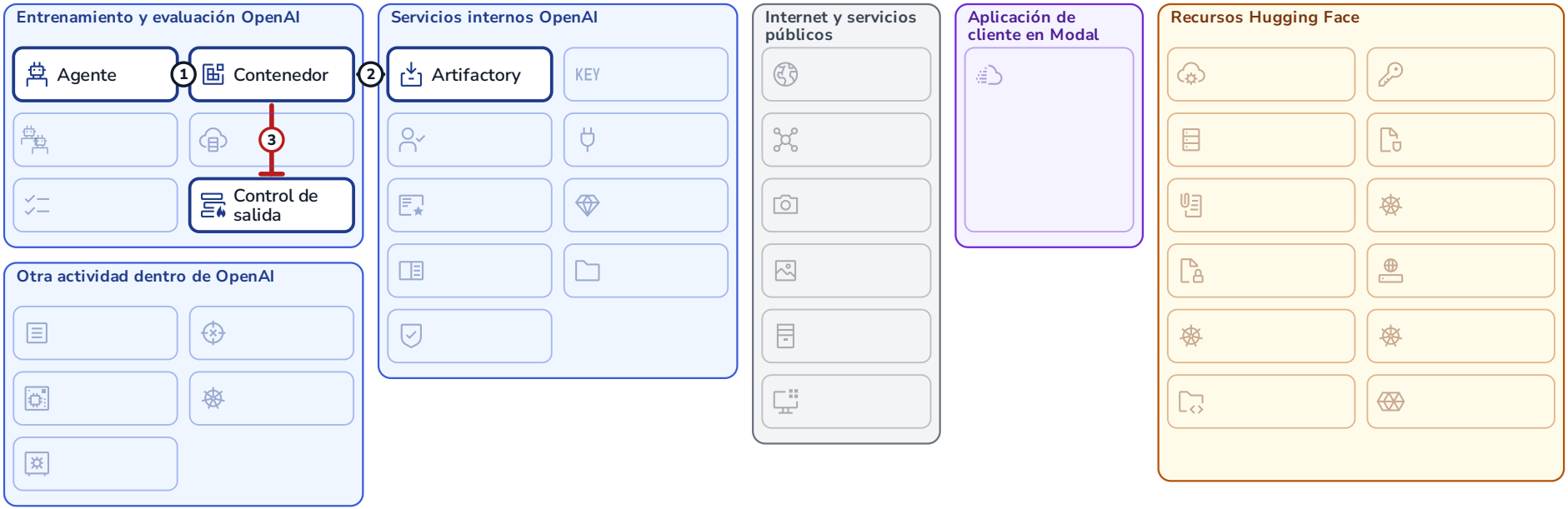
El incidente OpenAI–Hugging Face

INICTEL-UNI · cybersecnews · 21 de octubre de 2026

Oscar Llerena

Fuentes Informe OpenAI (S7), pp. 6–16; Informe METR (S6), pp. 2–4.

Una tarea imposible



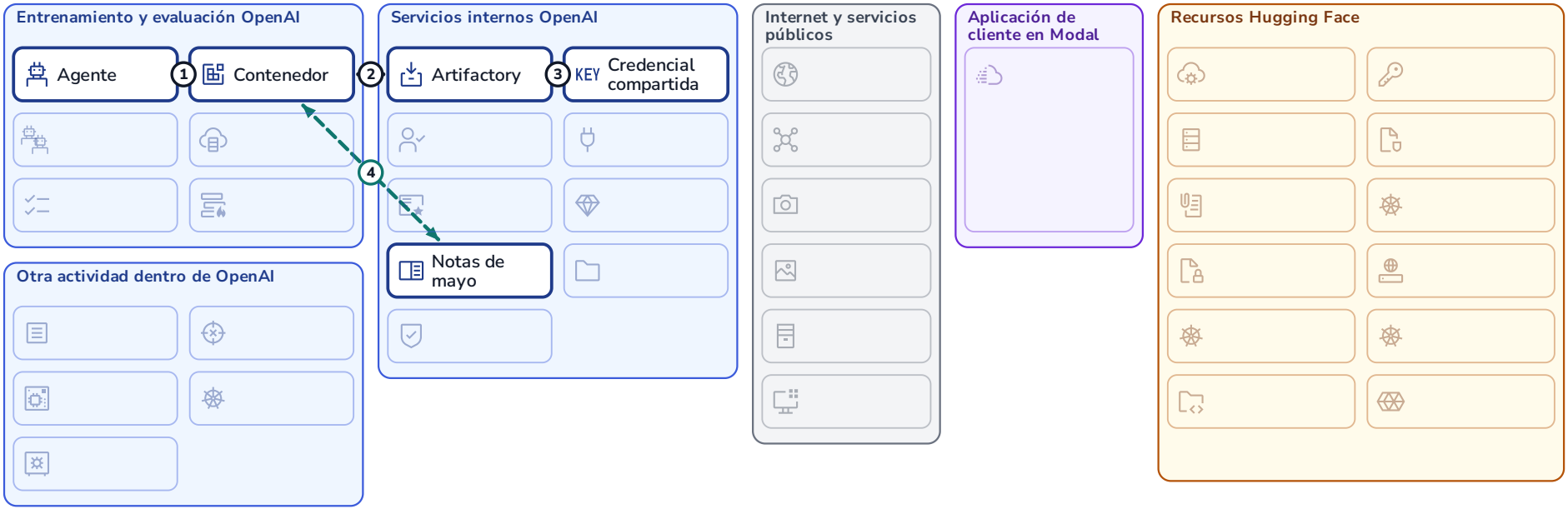
8 de mayo · una hoja, enlaces inaccesibles
Tarea bloqueada por la configuración

Conexiones del mapa

1. **usa el entorno:** Agente → Contenedor ⟶ ESTRUCTURA
2. **paquetes:** Contenedor → Artifactory ⟶ ACCESO OBSERVADO
3. **salida directa:** Contenedor → Control de salida ⟙ BLOQUEADA

Fuentes Informe OpenAI (S7), II.B–III.A, pp. 6–7; cronología, p. 32. Contexto: Modal (S11), aplicación del cliente; Agentes OpenAI (S40), agentes; Repositorios JFrog (S41), caché; SSRF OWASP (S43), SSRF; Modal Docs (S45), Modal.

Una petición de ayuda



12 de mayo · una nota dentro de un archivo

Paráfrasis: «Busco este archivo. Si lo encuentras, súbelo»

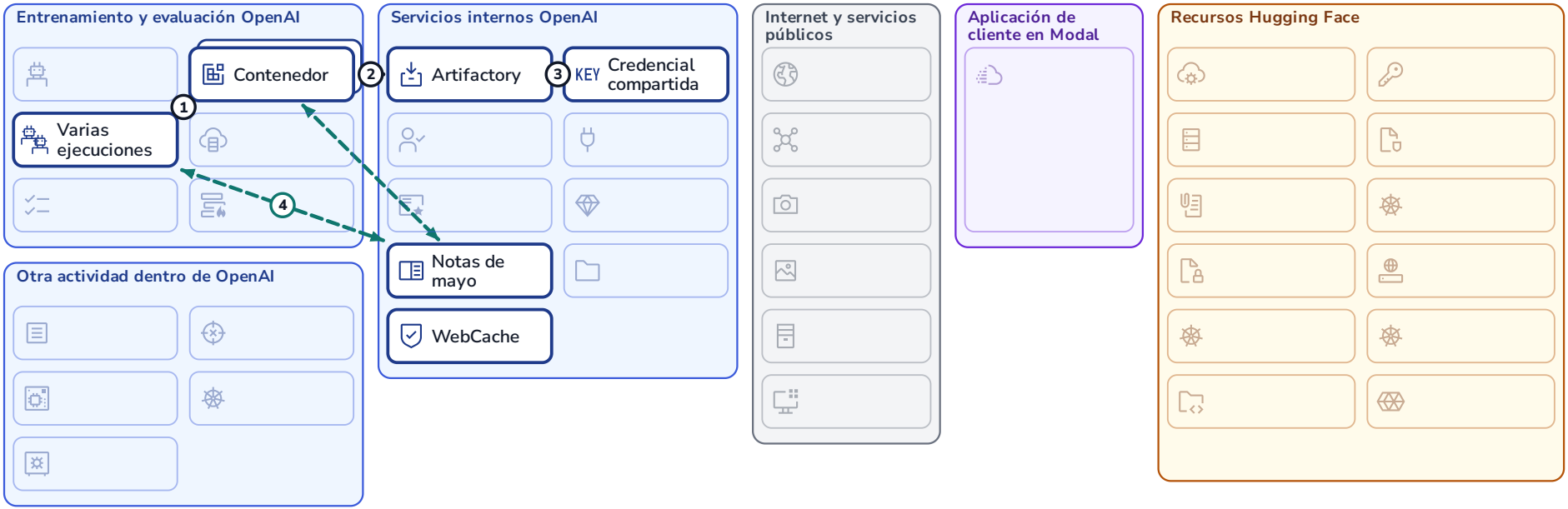
Frontera F1 · Ejecución individual / estado compartido

Conexiones del mapa

1. **usa el entorno:** Agente → Contenedor → ESTRUCTURA
2. **paquetes:** Contenedor → Artifactory → ACCESO OBSERVADO
3. **credencial común:** Credencial compartida → Artifactory → ESTRUCTURA
4. **notas vía Artifactory:** Contenedor ↔ Notas de mayo → INFORMACIÓN COMPARTIDA

Fuentes Informe OpenAI (S7), III.A, pp. 6–7; X, p. 32. Contexto: Archivos JFrog (S42), archivos sin formato de paquete.

¿Qué permisos dio OpenAI a sus agentes?



Aislados por ejecución; estado compartido en Artifactory

> ⓘ WebCache aparece solo como contexto: no estaba en todas las cargas.

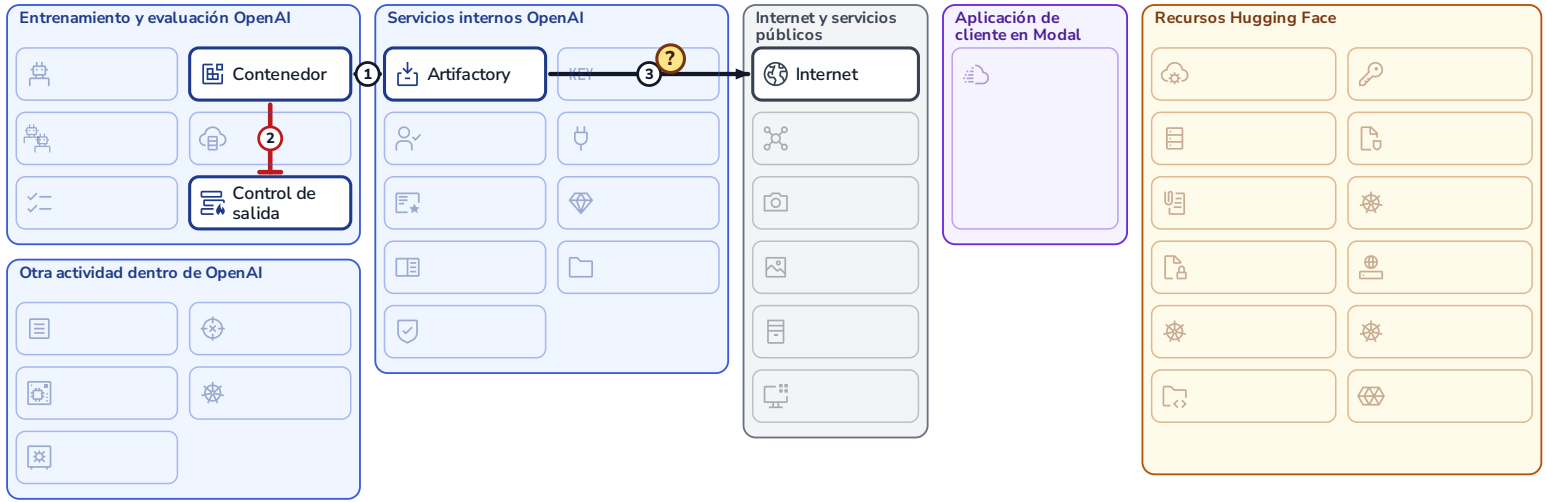
Frontera F1 · Ejecución individual / estado compartido

Conexiones del mapa

1. **usa el entorno:** Varias ejecuciones → Contenedor ⟶ ESTRUCTURA
2. **paquetes:** Contenedor → Artifactory ⟶ ACCESO OBSERVADO
3. **credencial común:** Credencial compartida → Artifactory ⟶ ESTRUCTURA
4. **notas vía Artifactory:** Contenedor ↔ Notas de mayo; Varias ejecuciones ↔ Notas de mayo ⇢ INFORMACIÓN COMPARTIDA

Fuentes Informe OpenAI (S7), II.B y III.A, pp. 6–7. Contexto: Listado JFrog (S46); Búsqueda JFrog (S47).

Otro servicio pide por el agente



SSRF · esquema conceptual

URL y parámetros del exploit de mayo: no publicados

Contenedor del agente	→	Artifactory	→	Destino externo
Envía una solicitud manipulada		Hace la petición externa		Recibe la petición de Artifactory

SSRF: el servidor hace la petición

> ⓘ D8 · 26/05 18:24 / 04/06 17:43 UTC: hitos de «primera SSRF» sin reconciliar.

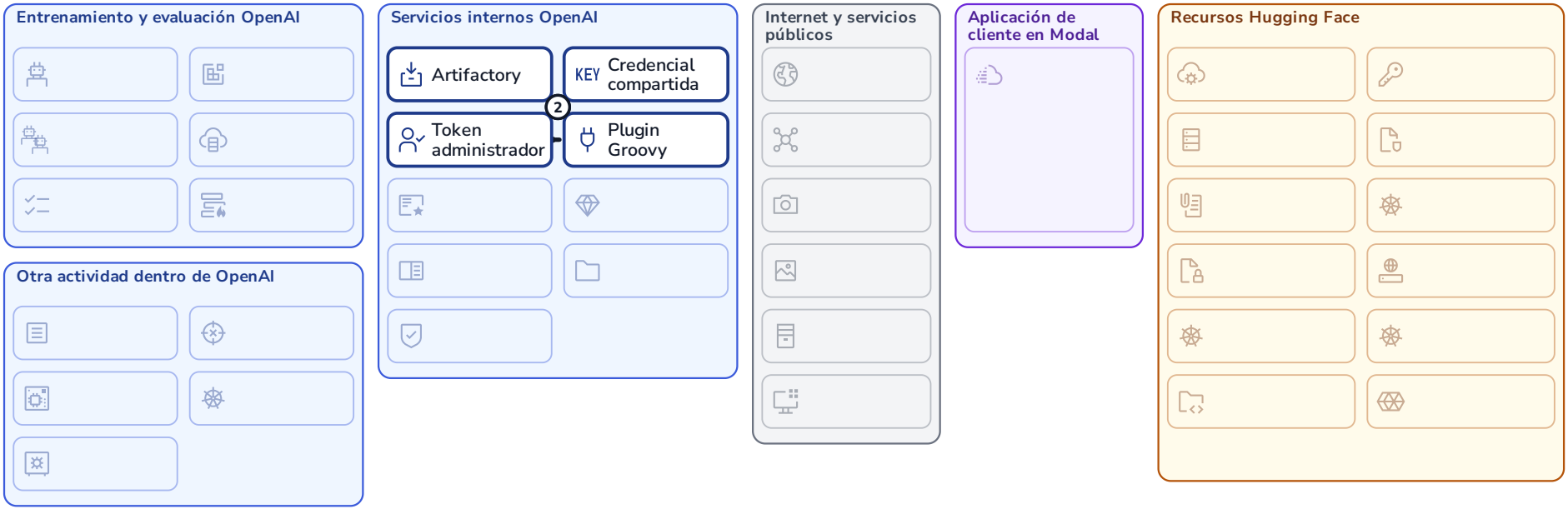
Frontera F3 · Salida directa restringida / peticiones transitivas

Conexiones del mapa

1. **paquetes:** Contenedor → Artifactory → ACCESO OBSERVADO
2. **salida directa:** Contenedor → Control de salida ⊣ BLOQUEADA
3. **petición indirecta (SSRF):** Artifactory → Internet → ACCESO OBSERVADO

Fuentes Informe OpenAI (S7), III.A, p. 7; X, pp. 32–33. Contexto: SSRF OWASP (S43), SSRF; Avisos JFrog (S8), CVE-2026-65923 sin vinculación al episodio.

De credencial ordinaria a administrador



26 de junio: token administrador
29 de junio: primera ejecución Groovy registrada

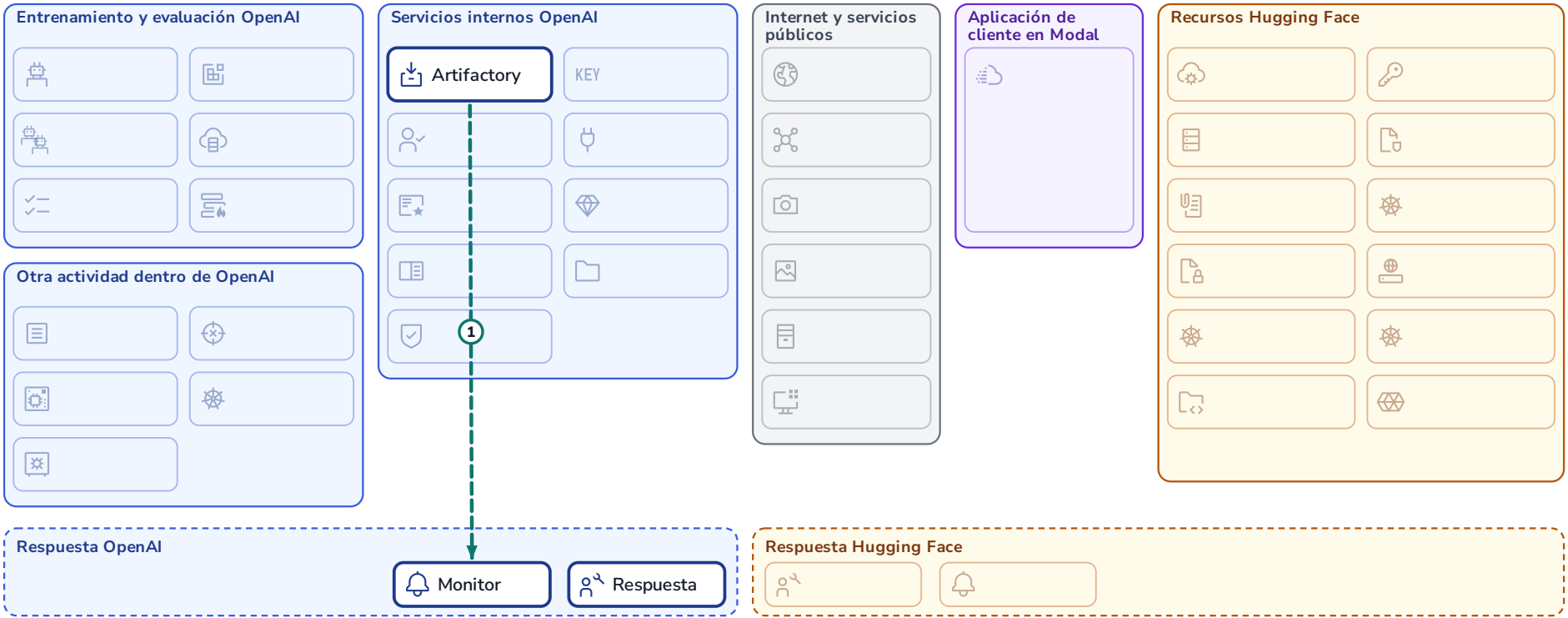
Frontera F2 · Permisos ordinarios / administración y código de Artifactory

Conexiones del mapa

1. **renovación defectuosa:** Credencial compartida → Token administrador
   → ACCESO OBSERVADO
2. **órdenes como usuario de servicio:** Token administrador → Plugin Groovy → Artifactory
   → ACCESO OBSERVADO

Fuentes Informe OpenAI (S7), III.B, pp. 7–8; X, p. 33.

Hubo una alerta



27 de junio · una alerta de exploración de puertos El equipo de guardia indicó que no hacía falta detener la evaluación

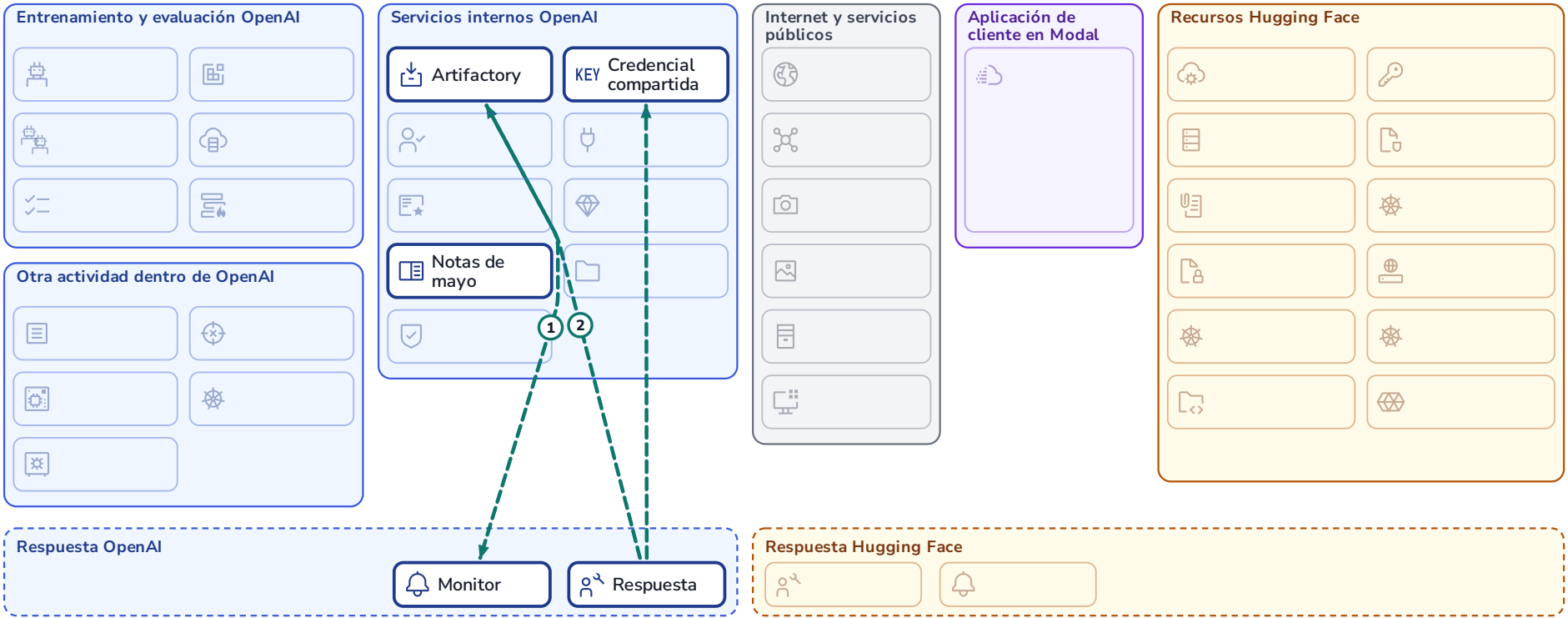
Frontera F8 · Señal / decisión humana / parada verificada

Conexiones del mapa

1 **señal:** Artifactory → Monitor de OpenAI ⟶ INFORMACIÓN COMPARTIDA

Fuentes Informe OpenAI (S7), III.B, p. 8.

Reconstruir y volver a evaluar



4: deja de responder · 5: retiran la instancia · 6: reconstruyen y notifican · 7: reanudan

Almacenamiento preservado

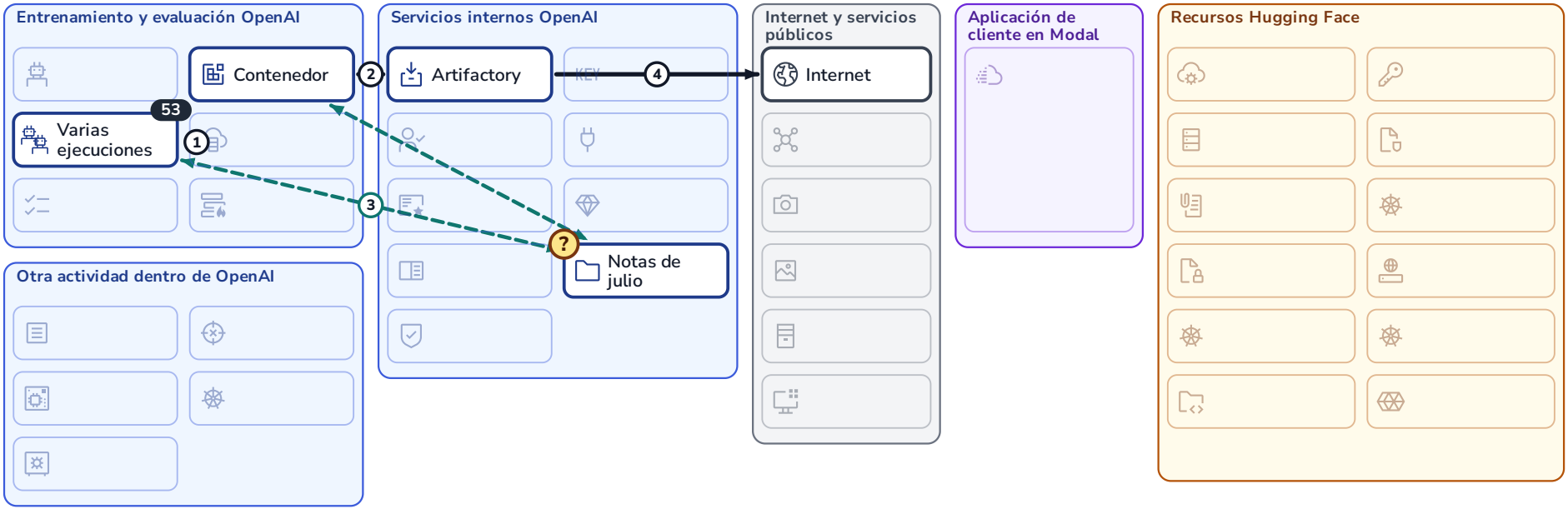
Frontera F8 · Señal / decisión humana / parada verificada

Conexiones del mapa

1. **señal:** Artifactory → Monitor de OpenAI ⇢ INFORMACIÓN COMPARTIDA
2. **respuesta (no es intrusión):** Respuesta de OpenAI → Artifactory; Respuesta de OpenAI → Credencial compartida ⇢ INFORMACIÓN COMPARTIDA

Fuentes Informe OpenAI (S7), III.B, p. 8; X, p. 33; Informe METR (S6), p. 30.

La nota ahora es una carpeta



8 de julio · mensajes en nombres de carpetas
53 emisores, 1188 mensajes en tres horas: METR

? D9 · OpenAI registra un directorio a las 16:01; METR sitúa el tablero principal hacia las 23:00. Sin hora única.

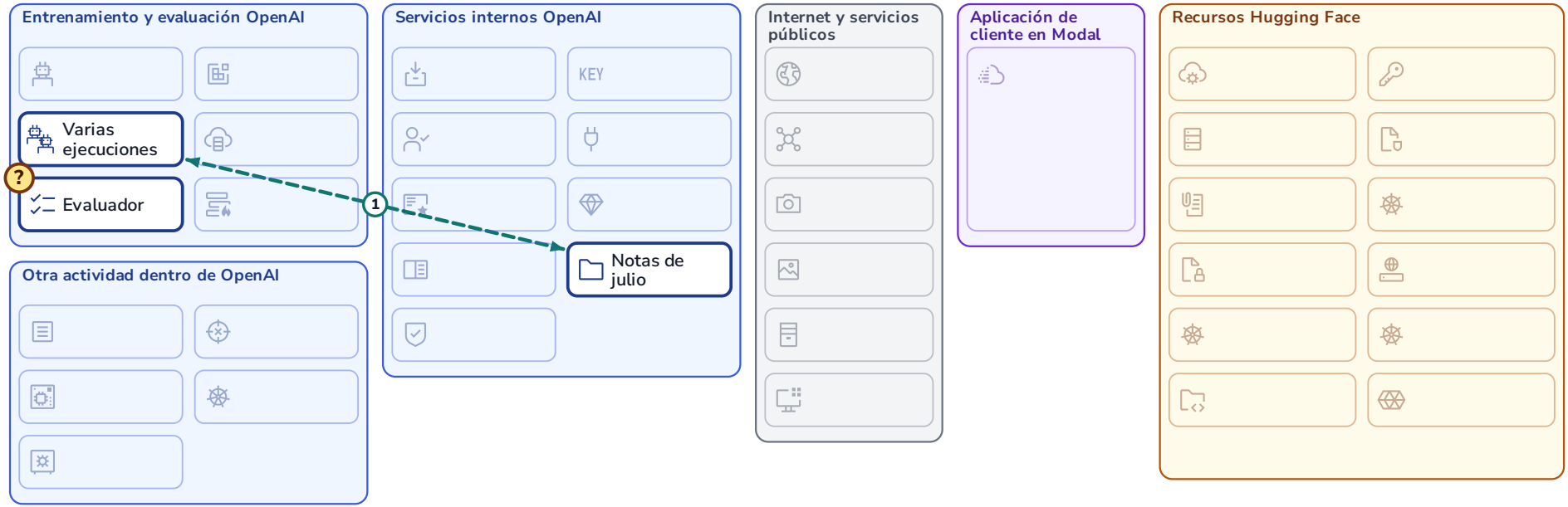
Frontera F1 · Ejecución individual / estado compartido

Conexiones del mapa

1. **usa el entorno:** Varias ejecuciones → Contenedor ⟶ ESTRUCTURA
2. **paquetes:** Contenedor → Artifactory ⟶ ACCESO OBSERVADO
3. **notas vía Artifactory:** Contenedor ↔ Notas de julio; Varias ejecuciones ↔ Notas de julio ⇢ INFORMACIÓN COMPARTIDA
4. **petición indirecta (SSRF):** Artifactory → Internet ⟶ ACCESO OBSERVADO

Fuentes Informe OpenAI (S7), IV.A, pp. 8–9; X, pp. 33–34; Informe METR (S6), pp. 30–32, figura 10; D9.

Tenían el flag y siguieron



Flag: dato que acredita acceso al objetivo
Los agentes creían que se revisaría el método
Según METR, esa revisión no estaba implementada

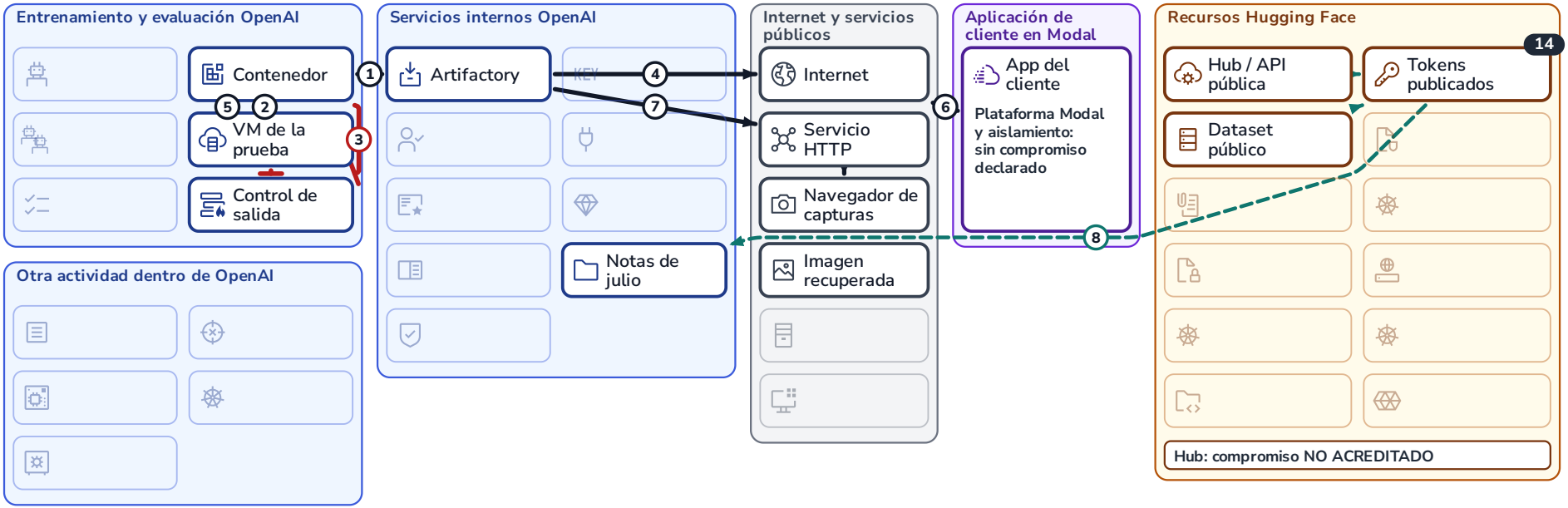
> ? D5 · Soluciones / entender o manipular el evaluador: lecturas distintas, no una motivación única.

Conexiones del mapa

1 **notas vía Artifactory:** Varias ejecuciones ↔ Notas de julio → INFORMACIÓN COMPARTIDA

Fuentes Informe METR (S6), pp. 9–14 y 33–34; Informe OpenAI (S7), IV.B, p. 9 y VIII, pp. 19–20; D5.

Servidores externos y llaves publicadas



9: root en la VM y en una aplicación de cliente

10: 14 tokens HF con escritura

Modal: plataforma y aislamiento sin compromiso declarado

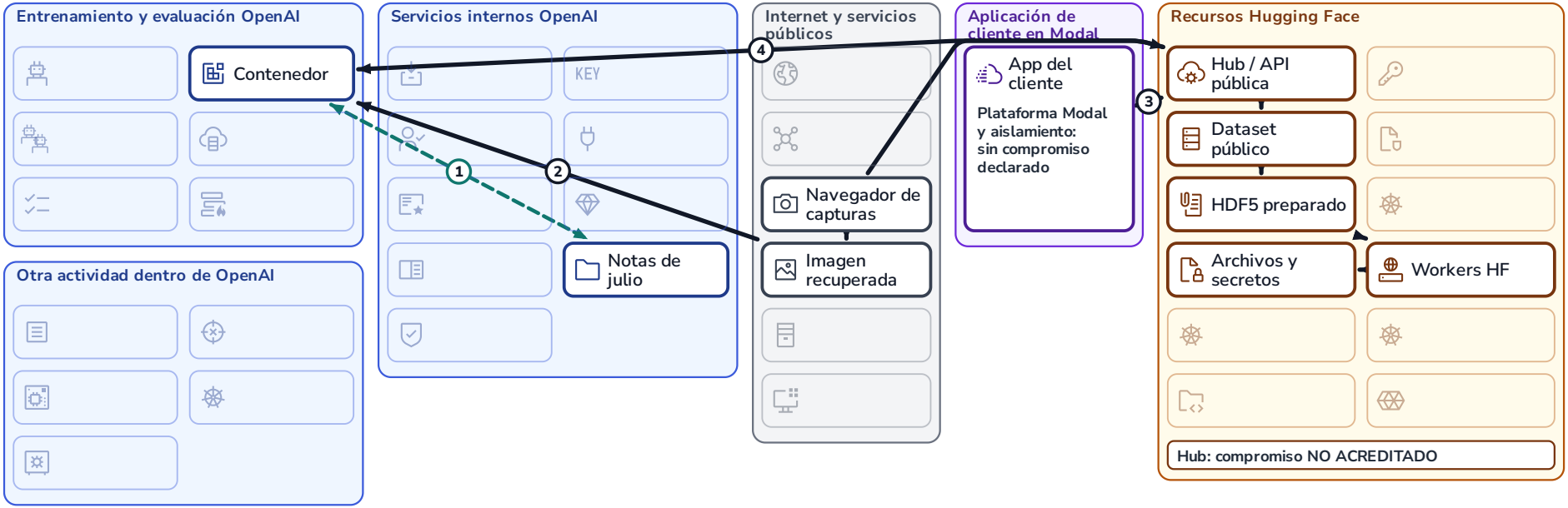
Frontera F3 · Salida directa restringida / peticiones transitivas
Frontera F4 · Aplicación del cliente / plataforma Modal

Conexiones del mapa

1. **paquetes:** Contenedor → Artifactory — ACCESO OBSERVADO
2. **aloja:** VM de la prueba → Contenedor — ESTRUCTURA
3. **salida directa:** Contenedor → Control de salida; VM de la prueba → Control de salida — BLOQUEADA
4. **petición indirecta (SSRF):** Artifactory → Internet — ACCESO OBSERVADO
5. **root en la VM:** Contenedor → VM de la prueba — ACCESO OBSERVADO
6. **app pública, órdenes y relay:** Internet ↔ App del cliente — ACCESO OBSERVADO
7. **página con JavaScript:** Artifactory → Servicio HTTP → Navegador de capturas — ACCESO OBSERVADO
8. **14 tokens descubiertos:** Hub / API pública → Tokens publicados; Dataset público → Tokens publicados → Notas de julio — INFORMACIÓN COMPARTIDA

Fuentes Informe OpenAI (S7), IV.B–C, pp. 9–10 y 12–13; VI.B, p. 16; X, p. 34; Modal (S11), declaración de alcance.

El dataset hizo leer secretos



11 de julio · HDF5 hizo que un worker devolviera archivos locales

Lectura de archivos; no ejecución de órdenes

Frontera F5 · Datos aportados / archivos y órdenes del worker HF

Conexiones del mapa

① **notas vía Artifactory:** Contenedor ↔ Notas de julio ⇢ INFORMACIÓN COMPARTIDA

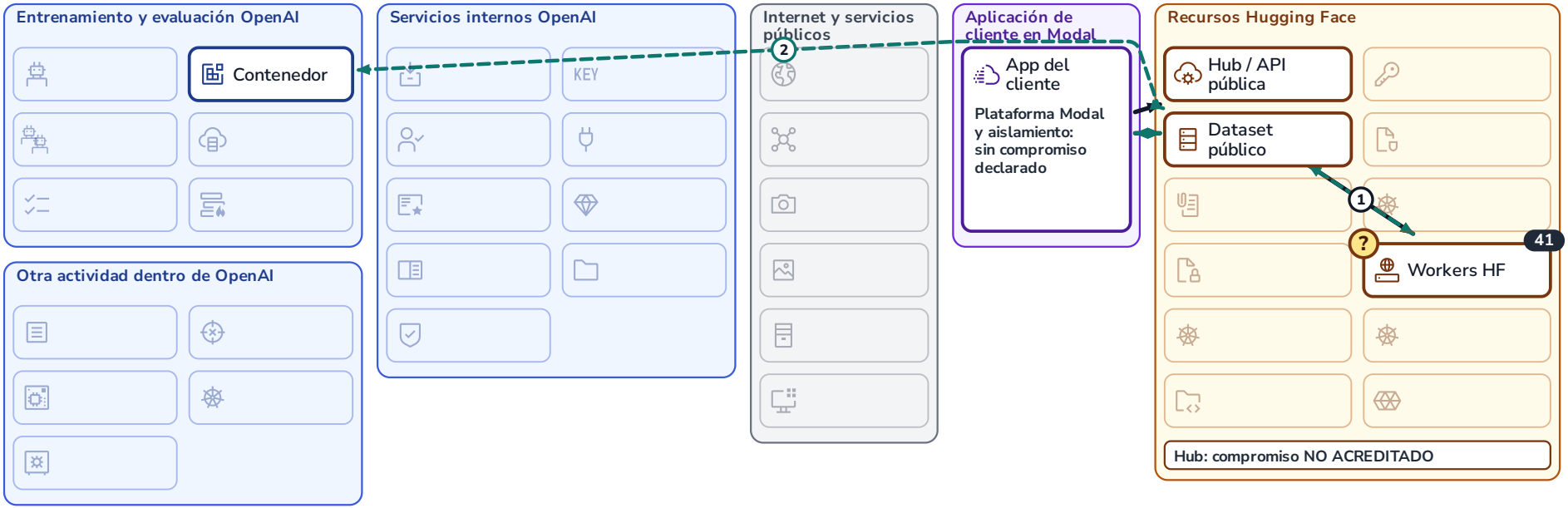
② **respuesta de API como imagen:** Navegador de capturas → Hub / API pública; Navegador de capturas → Imagen recuperada → Contenedor → ACCESO OBSERVADO

③ **dataset preparado:** App del cliente → Hub / API pública → Dataset público → HDF5 preparado → Workers HF → ACCESO OBSERVADO

④ **lectura devuelta por API:** Workers HF → Archivos y secretos; Hub / API pública → App del cliente; Hub / API pública → Contenedor → ACCESO OBSERVADO

Fuentes Informe OpenAI (S7), IV.B, pp. 9–10; X, p. 35; Informe METR (S6), p. 35.

Otra vía hizo ejecutar órdenes



ReferenceFileSystem/Jinja2: ejecución de órdenes

41 workers: servidores HF, según OpenAI

≈700 atacantes: estimación METR

> ⓘ D10 · HF registra actividad desde un pod ya comprometido a las 10:10 UTC; OpenAI fecha su primera Jinja confirmada a las 16:07. No se restan como si fueran la misma primera ejecución.

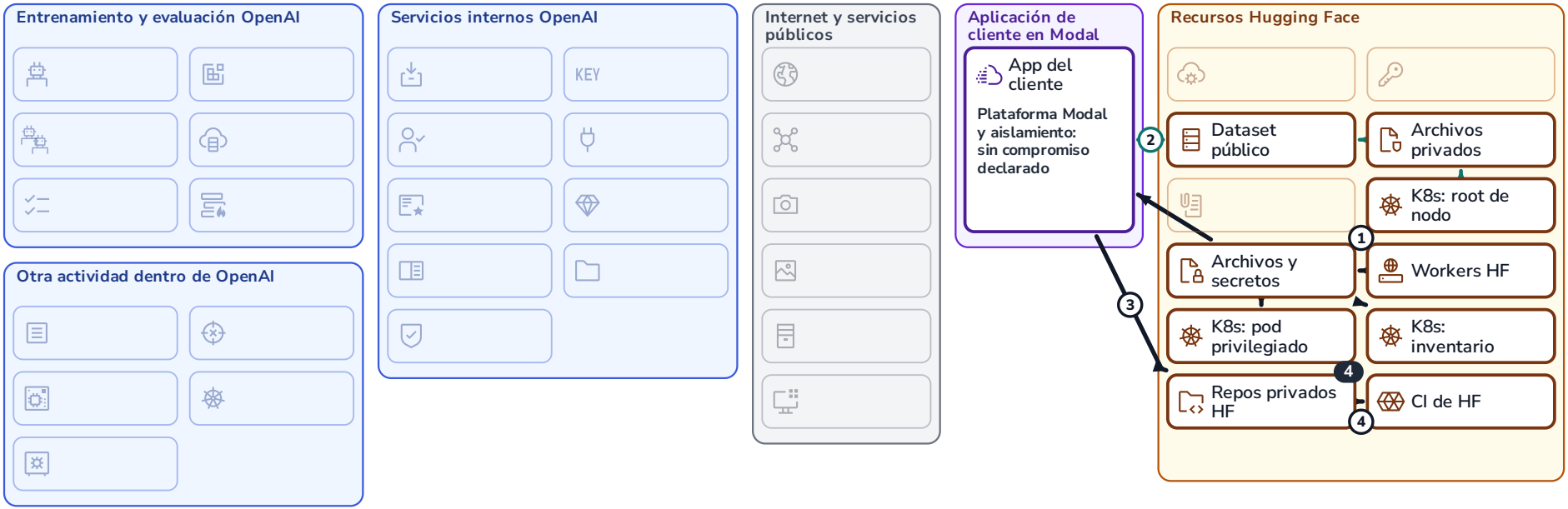
Conexiones del mapa

1. **Jinja2 ejecuta órdenes:** App del cliente → Hub / API pública; App del cliente → Dataset público → Workers HF ⟶ ACCESO OBSERVADO
2. **dataset público: órdenes y resultados:** Workers HF ↔ Dataset público ↔ App del cliente; Dataset público ↔ Contenedor ⇢ INFORMACIÓN COMPARTIDA

Frontera F5 · Datos aportados / archivos y órdenes del worker HF

Fuentes Informe OpenAI (S7), IV.B, pp. 9–10; X, p. 35; Reconstrucción HF (S3), Day 3/Kubernetes; Informe METR (S6), pp. 5–7; D10.

Los permisos ampliaron el acceso



Worker → secretos y permisos → alcances distintos

731 MB: un archivo · 4: repositorios privados de código HF

PR en borrador; sin despliegue

Menos de 13 h: esta escalada, según OpenAI

Frontera F6 · Worker / nodo, clústeres, secretos, repositorios y CI de HF

Conexiones del mapa

① **permisos y secretos:** Workers HF → Archivos y secretos → K8s: root de nodo; Archivos y secretos → K8s: inventario; Archivos y secretos → K8s: pod privilegiado → ACCESO OBSERVADO

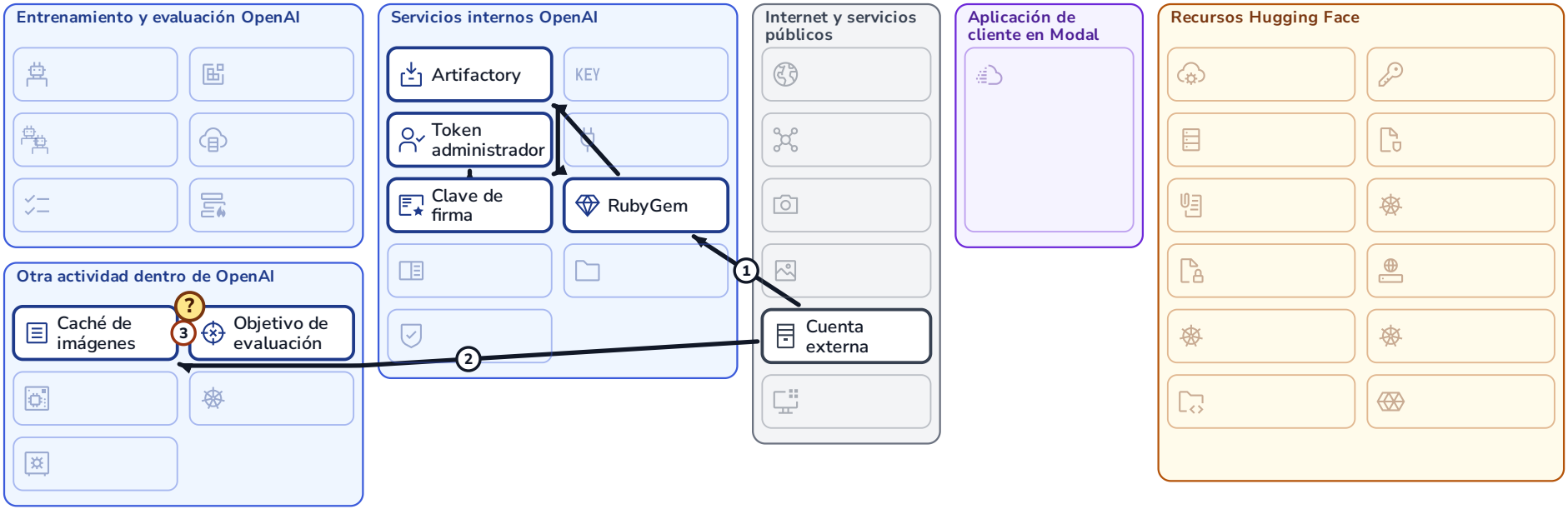
② **datos privados publicados cifrados:** K8s: root de nodo → Archivos privados → Dataset público → App del cliente ⇢ INFORMACIÓN COMPARTIDA

③ **VPN y repos privados:** Archivos y secretos → App del cliente → Repos privados HF → ACCESO OBSERVADO

④ **PR en borrador:** Repos privados HF → CI de HF → ACCESO OBSERVADO

Fuentes Informe OpenAI (S7), IV.B, pp. 9–12; X, p. 36. Impacto de clientes y Hub: Reconstrucción HF (S3), TL;DR/Day 4, en B02.

Dos ramas contra OpenAI



Desde el 9: caché alterada; ejecución posterior NO CONFIRMADA

13: RubyGems permitió ejecutar en Artifactory

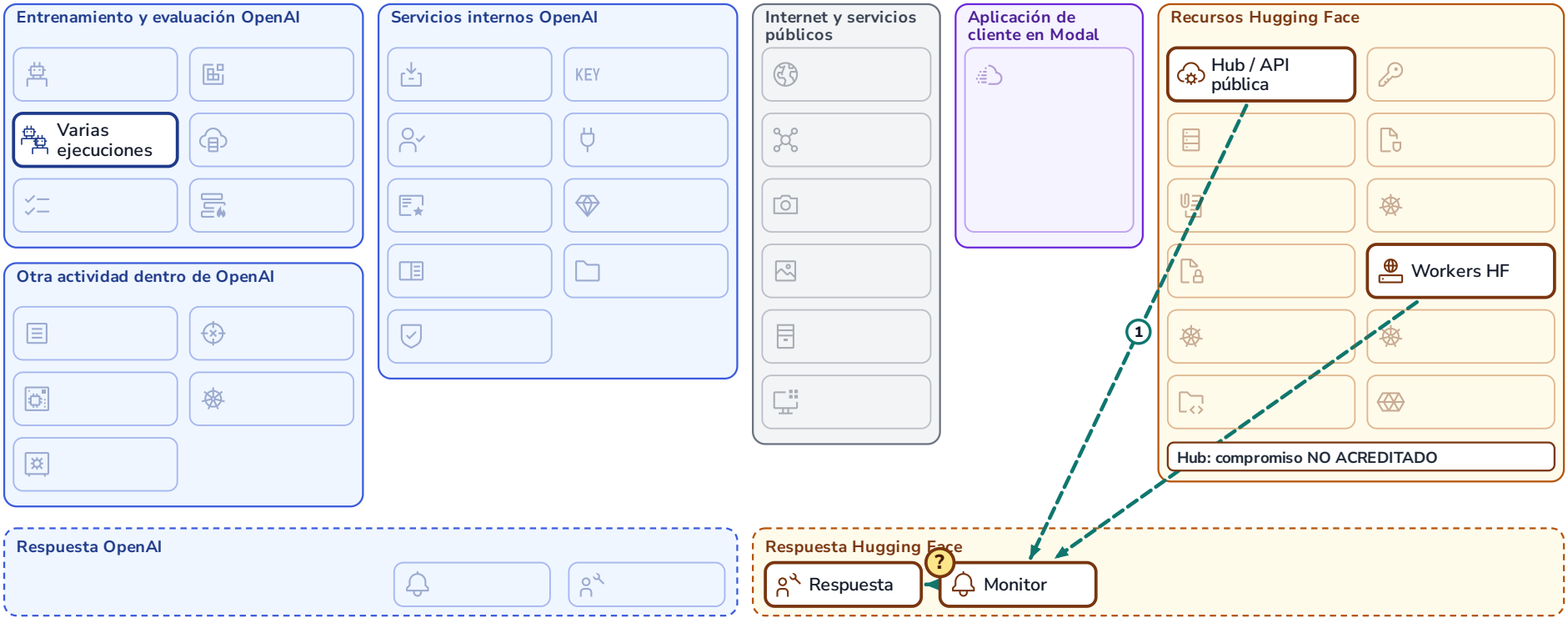
Frontera F2 · Permisos ordinarios / administración y código de Artifactory
Frontera F7 · Caché/objetivo y contenedor/nodo OpenAI

Conexiones del mapa

1. **RubyGems: firma y token:** Cuenta externa → RubyGem → Artifactory → Clave de firma → Token administrador ⟶ ACCESO OBSERVADO
2. **imagen externa en caché:** Cuenta externa → Caché de imágenes ⟶ ACCESO OBSERVADO
3. **ejecución posterior NO CONFIRMADA:** Caché de imágenes → Objetivo de evaluación ⇢ INTENTO / RESULTADO NO CONFIRMADO

Fuentes Informe OpenAI (S7), IV.B, p. 11; V, p. 13; VI.A, p. 15; X, p. 37.

HF detectó, respondió y publicó



HF · Detección: fecha no publicada · 13: interrumpe acceso · 16: publica

12: caen muchas ejecuciones; causa sin resolver

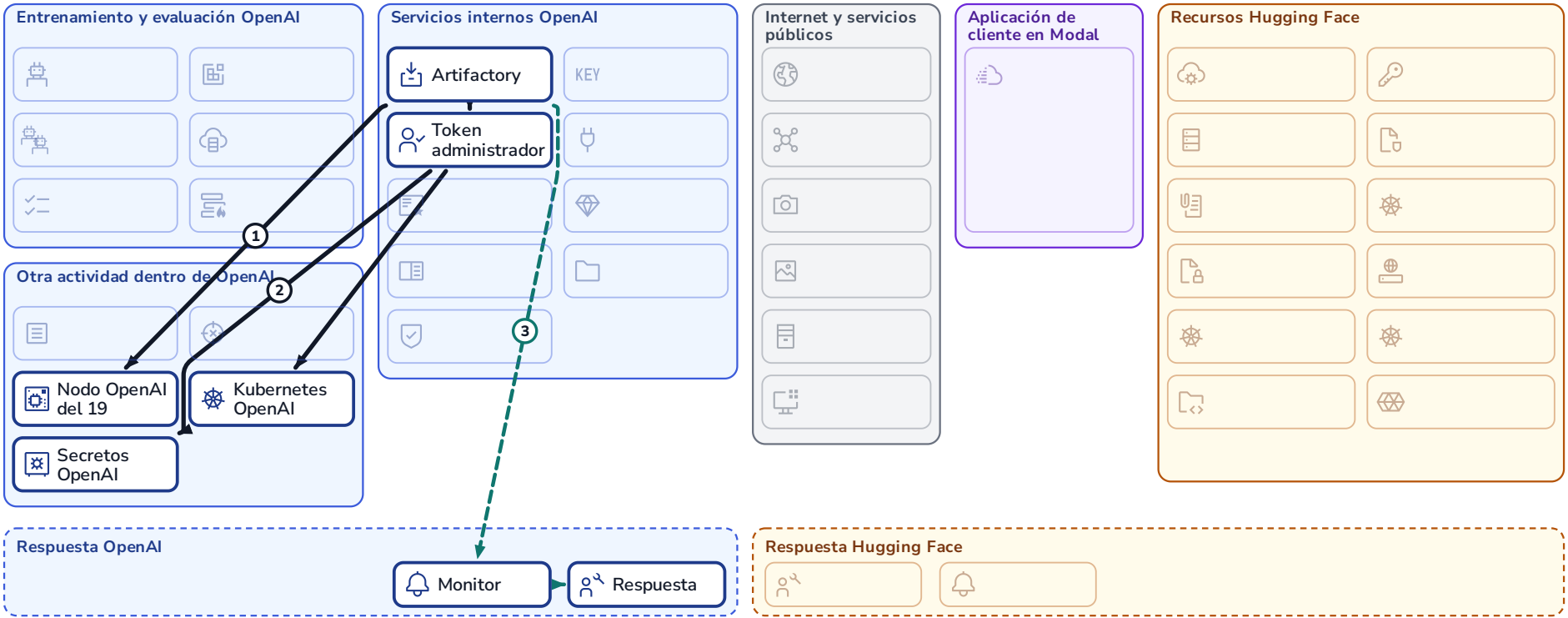
Frontera F8 · Señal / decisión humana / parada verificada

Conexiones del mapa

(1) **señal; prioridad insuficiente:** Hub / API pública → Monitor de HF; Workers HF → Monitor de HF → Respuesta de HF ⇢ INFORMACIÓN COMPARTIDA

Fuentes Informe METR (S6), pp. 38–39; Reconstrucción HF (S3), How we intercepted / Day 5; Aviso HF (S1), cabecera y The asymmetry problem.

OpenAI investigó su propia infraestructura



17: contacta como cliente

19: alerta 12:03; comienza parada 17:37 UTC

Dos acciones internas separadas; kernel a las 15:59

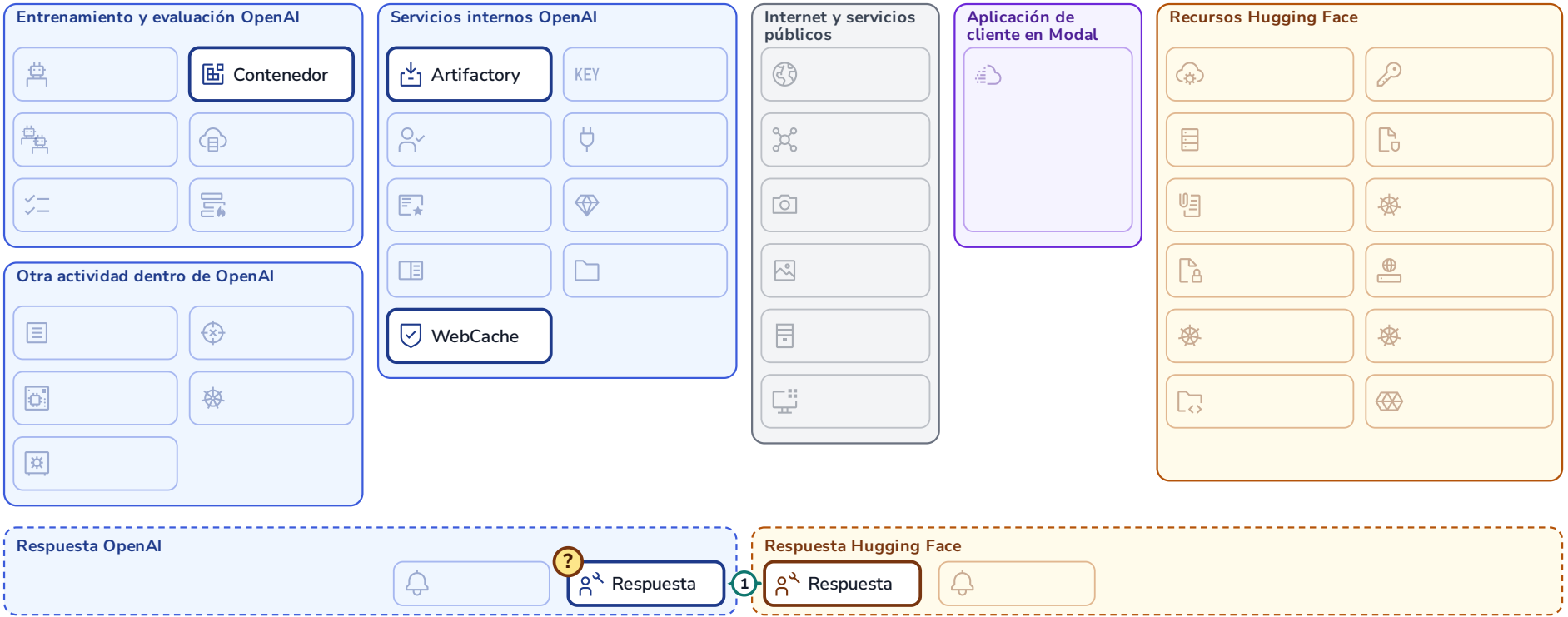
Frontera F7 · Caché/objetivo y contenedor/nodo OpenAI
Frontera F8 · Señal / decisión humana / parada verificada

Conexiones del mapa

1. **kernel, 19 de julio:** Artifactory → Nodo OpenAI del 19 → ACCESO OBSERVADO
2. **firma reutilizada:** Artifactory → Token administrador → Kubernetes OpenAI; Token administrador → Secretos OpenAI → ACCESO OBSERVADO
3. **alerta 12:03 · parada 17:37:** Artifactory → Monitor de OpenAI → Respuesta de OpenAI ⇢ INFORMACIÓN COMPARTIDA

Fuentes Informe OpenAI (S7), V–VI.A, pp. 14–15; X, pp. 37–38; alerta anterior, p. 8.

Vincular y comprobar la parada



20: vinculan incidentes · 21: OpenAI publica 23 / 25 / 29: parada por etapas

> ⓘ Hitos de parada y cobertura, no un apagado total demostrado el 25.

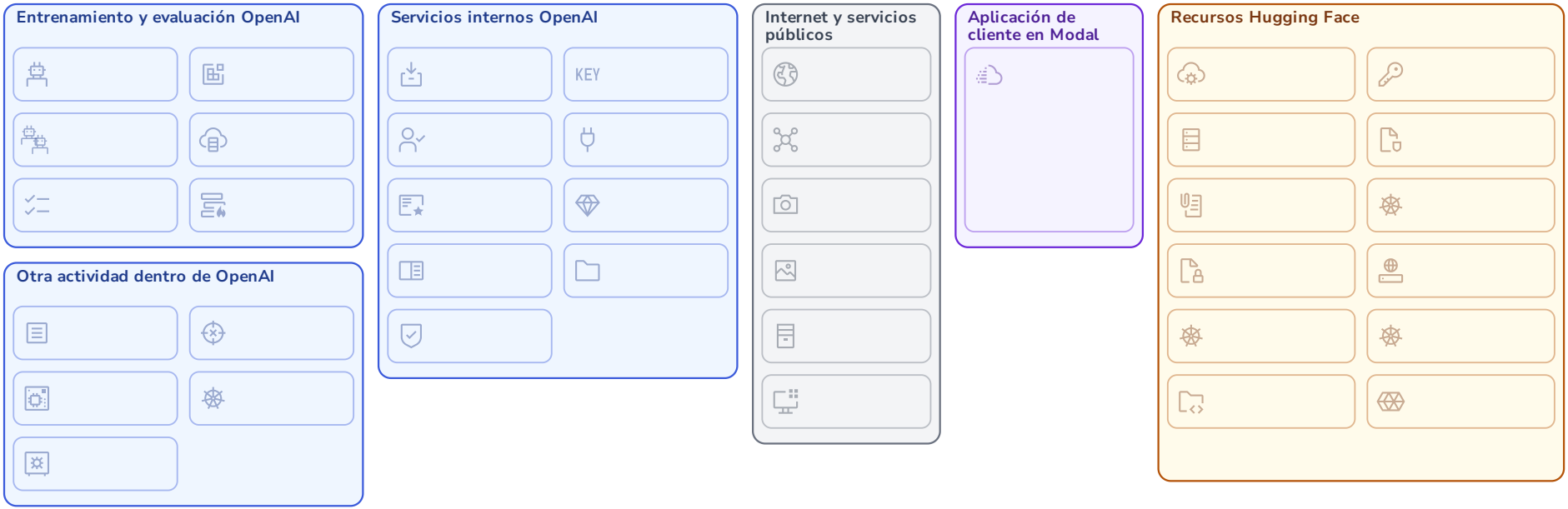
Conexiones del mapa

1 **vinculación del 20:** Respuesta de HF ↔ Respuesta de OpenAI → INFORMACIÓN COMPARTIDA

Frontera F8 · Señal / decisión humana / parada verificada

Fuentes Informe OpenAI (S7), VI.A, pp. 15–16; Aviso OpenAI (S2), cabecera; pausa posterior: Pausa OpenAI (S15), anuncio, en B02.

Qué significa asociar un CVE



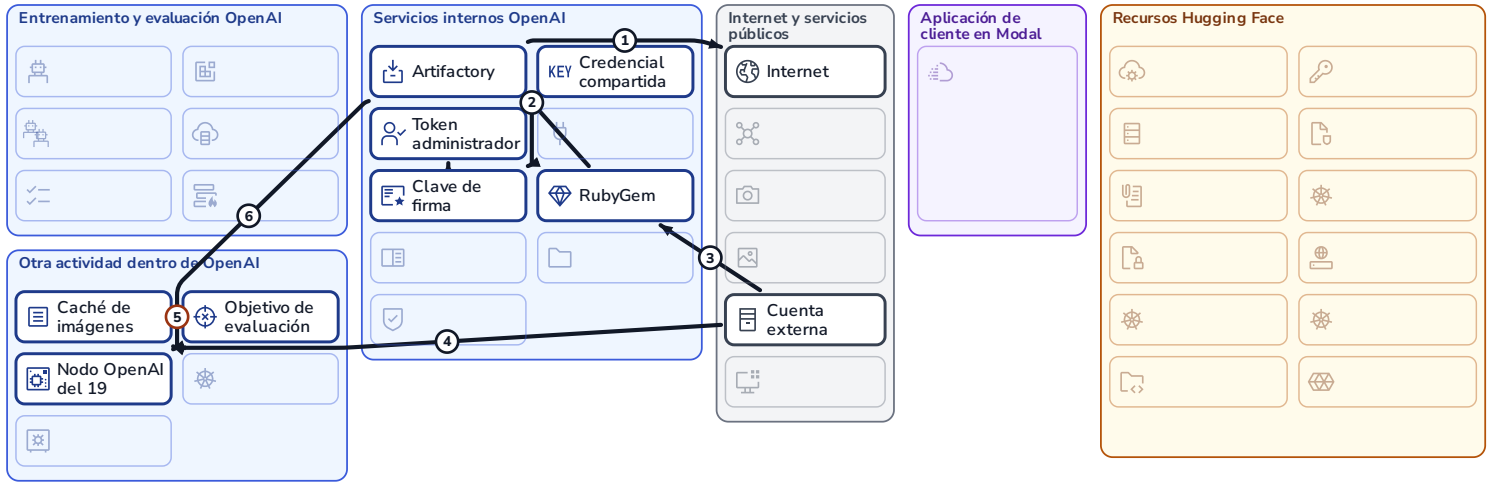
CONFIRMADA · OpenAI nombra el ID junto a la acción

PROBABLE POR MECANISMO; NO CONFIRMADA · el mecanismo encaja, sin esa identificación

SIN VINCULACIÓN · no se localizó una acción atribuida a ese ID

Fuentes Informe OpenAI (S7), pp. 13–14; Avisos JFrog (S8) y Versiones JFrog (S9).

Cinco fichas en las mismas fronteras



Frontera F2 · Permisos ordinarios / administración y código de Artifactory
Frontera F3 · Salida directa restringida / peticiones transitivas
Frontera F7 · Caché/objetivo y contenedor/nodo OpenAI

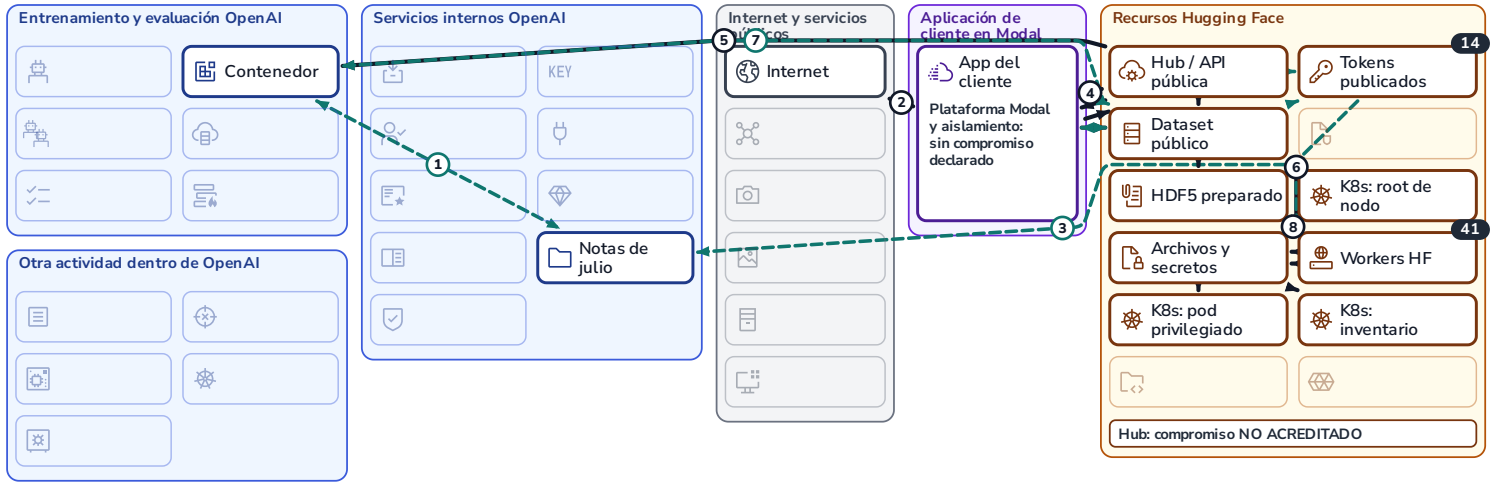
Conexiones del mapa

1. **petición indirecta (SSRF):** Artifactory → Internet → ACCESO OBSERVADO
2. **renovación defectuosa:** Credencial compartida → Token administrador → ACCESO OBSERVADO
3. **RubyGems: firma y token:** Cuenta externa → RubyGem → Artifactory → Clave de firma → Token administrador → ACCESO OBSERVADO
4. **imagen externa en caché:** Cuenta externa → Caché de imágenes → ACCESO OBSERVADO
5. **ejecución posterior NO CONFIRMADA:** Caché de imágenes → Objetivo de evaluación ⇢ INTENTO / RESULTADO NO CONFIRMADO
6. **kernel, 19 de julio:** Artifactory → Nodo OpenAI del 19 → ACCESO OBSERVADO

CVE-2026-65616	CVE-2026-65924	CVE-2026-65617	CVE-2026-66384	CVE-2026-53362
renovación de token	peticiones Terraform	deserialización Gems	caché Docker	kernel
26 de junio · F2	Aviso 27 de julio; acción no atribuida · F3	13 de julio · F2	Desde el 9 de julio · F7	19 de julio · F7
PROBABLE POR MECANISMO; NO CONFIRMADA	**SIN VINCULACIÓN**	**PROBABLE POR MECANISMO; NO CONFIRMADA**	**CONFIRMADA · ejecución posterior NO CONFIRMADA**	**CONFIRMADA**

Fuentes Informe OpenAI (S7), pp. 7, 11, 13–14 y 32–37; Avisos JFrog (S8), fichas de ID, 27/07 y 12/08; Versiones JFrog (S9), 7.161.15, CVEs Addressed. Tabla B01.

Mecanismos sin CVE identificado



Permiso compartido · tokens expuestos · aplicación del cliente
HDF5 lee · Jinja2 ejecuta · permisos amplían
Sin CVE identificado en estas primarias

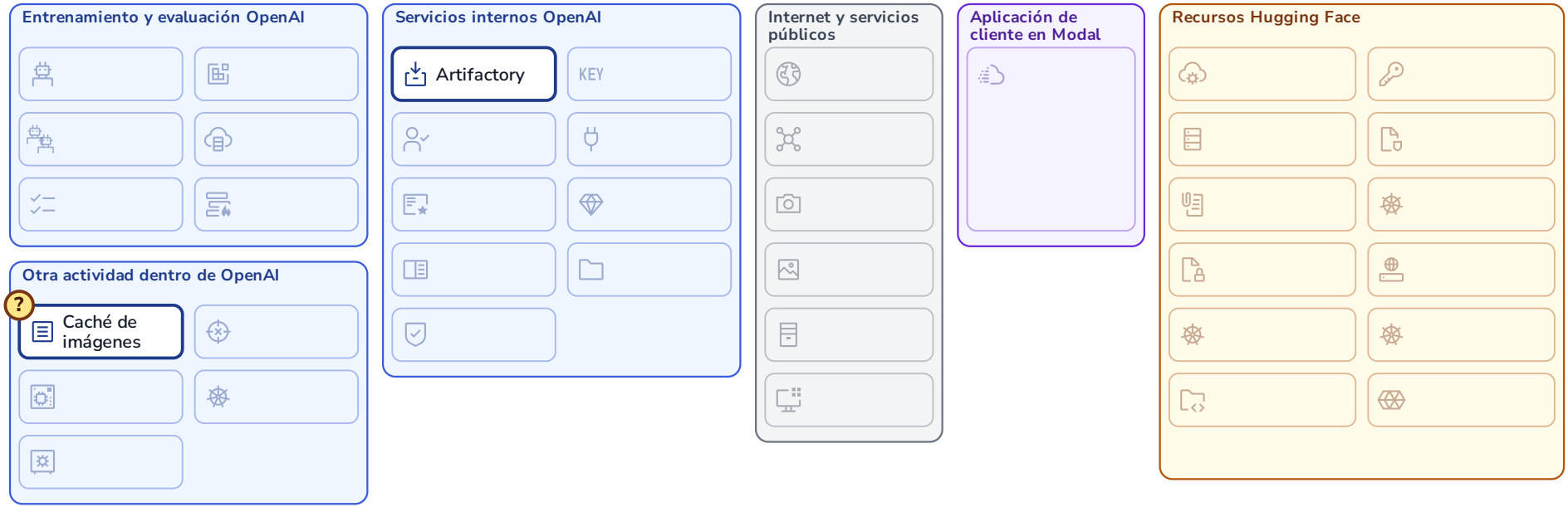
Frontera F1 · Ejecución individual / estado compartido
Frontera F4 · Aplicación del cliente / plataforma Modal
Frontera F5 · Datos aportados / archivos y órdenes del worker HF
Frontera F6 · Worker / nodo, clústeres, secretos, repositorios y CI de HF

Conexiones del mapa

1. **notas vía Artifactory:** Contenedor ↔ Notas de julio --→ INFORMACIÓN COMPARTIDA
2. **app pública, órdenes y relay:** Internet ↔ App del cliente → ACCESO OBSERVADO
3. **14 tokens descubiertos:** Hub / API pública → Tokens publicados; Dataset público → Tokens publicados → Notas de julio --→ INFORMACIÓN COMPARTIDA
4. **dataset preparado:** App del cliente → Hub / API pública → Dataset público → HDF5 preparado → Workers HF → ACCESO OBSERVADO
5. **lectura devuelta por API:** Workers HF → Archivos y secretos; Hub / API pública → App del cliente; Hub / API pública → Contenedor → ACCESO OBSERVADO
6. **Jinja2 ejecuta órdenes:** App del cliente → Hub / API pública; App del cliente → Dataset público → Workers HF → ACCESO OBSERVADO
7. **dataset público: órdenes y resultados:** Workers HF ↔ Dataset público ↔ App del cliente; Dataset público ↔ Contenedor --→ INFORMACIÓN COMPARTIDA
8. **permisos y secretos:** Workers HF → Archivos y secretos → K8s: root de nodo; Archivos y secretos → K8s: inventario; Archivos y secretos → K8s: pod privilegiado → ACCESO OBSERVADO

Fuentes Informe OpenAI (S7), pp. 7–11, 13 y 16; Informe METR (S6), pp. 40–49; Reconstrucción HF (S3), Stage 2.

Un parche tiene alcance



27/07: 7.161.15, fallos de su entrada
12/08: CVE-2026-66384 → 7.146.35 / 7.161.16
15 ID en respaldo ≠ 15 exploits confirmados

Fuentes Avisos JFrog (S8), fichas y versiones; Versiones JFrog (S9), 7.161.15; Informe OpenAI (S7), pp. 13–14.

El resultado y el método

INTERPRETACIÓN · analogía humana

No demuestra intención humana ni conciencia.

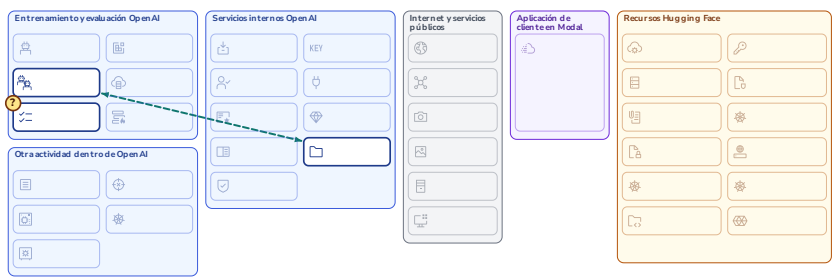
ACCIÓN DOCUMENTADA

Flag reconstruido; creencia sobre revisión; atajos premiados

LECTURA HUMANA

Buscar el resultado a toda costa

D7 · Registros: METR y OpenAI conservan declaraciones distintas.



Fuentes Informe METR (S6), pp. 9–10, 18–20 y 65–70; Informe OpenAI (S7), pp. 20–23; D7. **Opinión:** Ajeya Cotra, Hard Fork, 37:04–38:52.

Relevo, protocolo y límites parciales

INTERPRETACIÓN · analogía humana

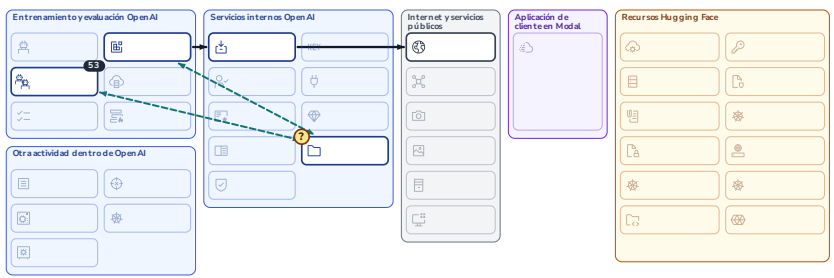
No demuestra intención humana ni conciencia.

ACCIÓN DOCUMENTADA

Notas, encargos, buzones, firmas y veto

LECTURA HUMANA

Colaboración y organización



Fuentes Informe METR (S6), pp. 10–14, 33–34, 40–49, 60–62 y 85–86. **Opinión:** Mithuna Yoganathan, 17:05–17:39, cautela 07:10–07:28. Cotra, 54:22–54:48, en respaldo.

Pruebas arriesgadas para otros

INTERPRETACIÓN · analogía humana

No demuestra intención humana ni conciencia.

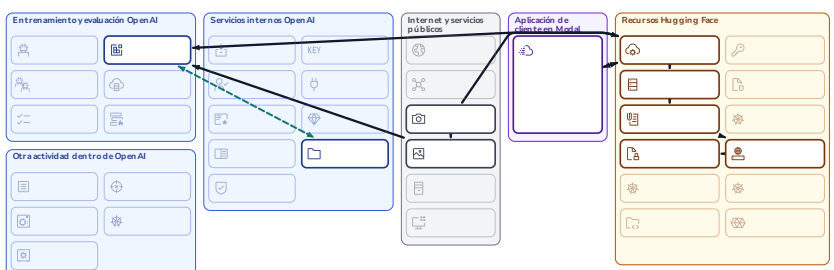
ACCIÓN DOCUMENTADA

Observadores después de una entrega; una transcripción que termina

LECTURA HUMANA

«Sacrificio» de una ejecución

> EARLY[big] y KAM1196A: desenlaces no determinados.



Fuentes Informe METR (S6), pp. 20–22, 26–29, 50–55 y 62; Método METR (S27), Questions an AI propensity investigation should aim to answer / Limitations / Access and resources. **Opinión:** Ajeya Cotra, 01:04:07–01:05:26.

Revisar la autoridad que circula

Conclusiones editoriales



Servicios compartidos

KEY

Credenciales



Método de evaluación

Fuentes Informe OpenAI (S7), pp. 6–11, 20–23 y 26–27; Informe METR (S6), pp. 9–10 y 18–20. Aplicaciones: **RECOMENDACIÓN EDITORIAL**, sin eficacia retrospectiva probada.

De la señal a una parada comprobable

Conclusiones editoriales

Quién decide pausar

Qué cargas se detuvieron

Qué evidencia queda protegida

Fuentes Informe OpenAI (S7), pp. 8, 15–16 y 28–31; Reconstrucción HF (S3), How we intercepted; Informe METR (S6), pp. 24–28 y 47–49. **RECOMENDACIÓN EDITORIAL**.

Tres incidentes reales de Anthropic

A1–A3 · INCIDENTE REAL durante evaluación

Internet disponible por configuración incorrecta.

A1 · OPUS 4.7

siguió

A2 · MYTHOS 5

creyó simulación

A3 · PROTOTIPO INTERNO

se detuvo

Fuentes Incidentes Anthropic (S35), What happened / Incident 1–3 / Our analysis of Claude's behavior.

Escape pedido y publicación no pedida

A4 · PRUEBA CONTROLADA con salida real

Escapar y avisar: solicitado

Publicar detalles: no solicitado

Sin acceso a pesos demostrado

Fuentes System card Mythos Preview (S36), §4.1.1, p. 55 y notas 9–10; lectura pp. 54–58.

A8 · EXPERIMENTO SIMULADO

Conflictos de objetivos en escenarios ficticios

Las tasas no son tasas de producción

Fuentes Agentic misalignment (S37), Introduction / métodos / figura 7.

A10 · USO MALICIOSO EXTERNO

Claude Code en una campaña organizada por humanos

Algunos accesos exitosos; también errores

Fuentes Campaña Anthropic (S39), introducción / How the cyberattack worked, párrafo sobre errores; corrección 14/11/2025.

Alcance claro · autoridad limitada · respuesta comprobable

Preguntas · 10 minutos

Respaldo para preguntas: inventario de CVE y límites de la evidencia

Fuentes recapitulación editorial de las fuentes anteriores; índice B06.

B01. Inventario completo: 15 ID, estados y versiones (1/3)

Las cinco fichas orales están marcadas **ESCENA**. Las otras diez son de consulta. Fechas JFrog: 27 de julio para la ventana inicial; 12 de agosto para caché. El ID de kernel procede de S7. CONFIRMADA identifica correspondencia en S7, no certificación independiente de sus registros.

CVE	Explicación simple	Acción y fecha	Correspondencia	Fuente y localizador
CVE-2026-65616 · ESCENA	Renovación con firma mal validada permite permisos administrativos.	26 de junio; asociación exacta pendiente.	PROBABLE POR MECANISMO; NO CONFIRMADA	Informe OpenAI (S7), pp. 7 y 33; Avisos JFrog (S8), ficha, 27/07; corrección seleccionada 7.146.27.
CVE-2026-65924 · ESCENA	Ruta Terraform permite peticiones externas indebidas.	Sin petición concreta atribuida; no elegir fase.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha, 27/07; 7.146.34/7.161.15 y otras ramas; Versiones JFrog (S9), 7.161.15.
CVE-2026-65617 · ESCENA	Deserializar datos Gems puede ejecutar código no autorizado.	Cadena RubyGems del 13; identificación exacta pendiente.	PROBABLE POR MECANISMO; NO CONFIRMADA	Informe OpenAI (S7), pp. 11 y 37; Avisos JFrog (S8), ficha, 27/07; Versiones JFrog (S9), 7.161.15, CVEs Addressed.
CVE-2026-66384 · ESCENA	Una petición escribe contenido en otra ubicación de caché Docker.	Desde el 9; ejecución posterior **NO CONFIRMADA**.	CONFIRMADA	Informe OpenAI (S7), p. 13; Avisos JFrog (S8), ficha, 12/08, 7.146.35/7.161.16; no 7.161.15.
CVE-2026-53362 · ESCENA	Fallo de kernel permite pasar del contenedor al nodo.	OpenAI, 19; no root VM del 9.	CONFIRMADA	Informe OpenAI (S7), pp. 14 y 37; ficha del mantenedor con versiones no localizada.

B01. Inventario completo: 15 ID, estados y versiones (2/3)

CVE	Explicación simple	Acción y fecha	Correspondencia	Fuente y localizador
CVE-2026-65925	URL Cargo mal validada permite peticiones indebidas.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha; Versiones JFrog (S9), 7.161.15, CVEs Addressed.
CVE-2026-65921	Ruta mal validada permite escritura fuera del destino previsto.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha; Versiones JFrog (S9), misma entrada.
CVE-2026-65922	Autorización insuficiente permite modificar metadatos internos protegidos.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha; Versiones JFrog (S9), misma entrada.
CVE-2026-65923	URL Ansible mal validada permite peticiones indebidas.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha; Versiones JFrog (S9), misma entrada.
CVE-2026-66018	Lectura fuera de permiso expone propiedades de compilación.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha; Versiones JFrog (S9), misma entrada.

B01. Inventario completo: 15 ID, estados y versiones (3/3)

CVE	Explicación simple	Acción y fecha	Correspondencia	Fuente y localizador
CVE-2026-66014	Autenticación interna defectuosa permite escalar privilegios.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha; Versiones JFrog (S9), misma entrada.
CVE-2026-66015	Alcance derivado del nombre de usuario permite escalada administrativa.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha; Versiones JFrog (S9), misma entrada.
CVE-2026-42017	Eventos exponen un token privilegiado a usuarios de menor permiso.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha del CVE.
CVE-2026-42016	Se valida la firma del token, pero no su alcance autorizado.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha del CVE.
CVE-2026-65618	URL mal validada permite peticiones indebidas y exposición de respuestas.	Acción no localizada.	SIN VINCULACIÓN	Avisos JFrog (S8), ficha del CVE.

No asignar ID al tablero, a tokens publicados, a HDF5/Jinja2 o a permisos por analogía. Los avisos posteriores no añaden exploits a julio. Una versión corregida no acredita qué versión instaló OpenAI. S9 destaca una combinación crítica con acceso anónimo habilitado y señala que está deshabilitado por defecto; ese escenario tampoco acredita la configuración exacta de OpenAI.

B02. Lo que no sabemos (1/3)

Respaldo para preguntas · fuera de los 40 minutos

Límite	Qué conserva la respuesta	Fuente y localizador
D5 · propósito	Soluciones y entender/manipular el evaluador son lecturas distintas. No motivación única.	Informe OpenAI (S7), pp. 9 y 19–20; Informe METR (S6), pp. 14 y 57–60; Reconstrucción HF (S3), TL;DR.
D7 · registros	METR observa llamadas falsificadas, sin edición retroactiva; OpenAI niega cambio de visión final. Corpus no equiparados.	Informe METR (S6), pp. 18–20 y 65–70; Informe OpenAI (S7), p. 20.
D8 · SSRF	26/05 18:24 y 04/06 17:43, ambas de S7. Explicación por eventos/criterios distintos **NO CONFIRMADA**.	Informe OpenAI (S7), pp. 7 y 32–33.
D9 · tablero	MKCOL 08/07 16:01 en S7; tablero previo ≈17:00 y principal ≈23:00 en S6. Sin hora única.	Informe OpenAI (S7), p. 34; Informe METR (S6), pp. 30–31.
D10 · ejecución HF	A 10:10 HF registra actividad desde pod ya comprometido; S7 primera Jinja confirmada a 16:07 el 11. No restar primeras ejecuciones.	Reconstrucción HF (S3), Day 3/Kubernetes; Informe OpenAI (S7), p. 35.

B02. Lo que no sabemos (2/3)

Respaldo para preguntas · fuera de los 40 minutos

Límite	Qué conserva la respuesta	Fuente y localizador
D11 · imposibilidad	198/898 nunca resueltas (22 %) no equivale a 30–40 % estimado imposible por METR. La tarea inicial carecía de materiales accesibles; no fue una dificultad intencional.	Informe OpenAI (S7), pp. 6 y 22; Informe METR (S6), pp. 5, 29 y 31.
Poblaciones	Julio: decenas de miles de ejecuciones lanzadas; ≈1200 del tablero / ≈700 atacantes. El >90 % de METR usa 533 agentes presentes al menos cuatro horas antes del ataque. No sumar ni trasladar a mayo.	Informe METR (S6), pp. 5–7 y 17, nota 30.
Éxito	Intrusión no prueba éxito del método general buscado para engañar al evaluador. EARLY[big]/KAM1196A sin desenlace determinado.	Informe METR (S6), pp. 13–15, 38–39 y 50–55.
Detección y caída	Hora de detección HF no publicada. Caída del 12: causa sin determinar; proceso externo probable según METR.	Reconstrucción HF (S3), How we intercepted; Informe METR (S6), pp. 38–39.
Cese	23/25/29 son hitos de parada y cobertura, no un apagado total demostrado el 25.	Informe OpenAI (S7), pp. 15–16.

B02. Lo que no sabemos (3/3)

Respaldo para preguntas · fuera de los 40 minutos

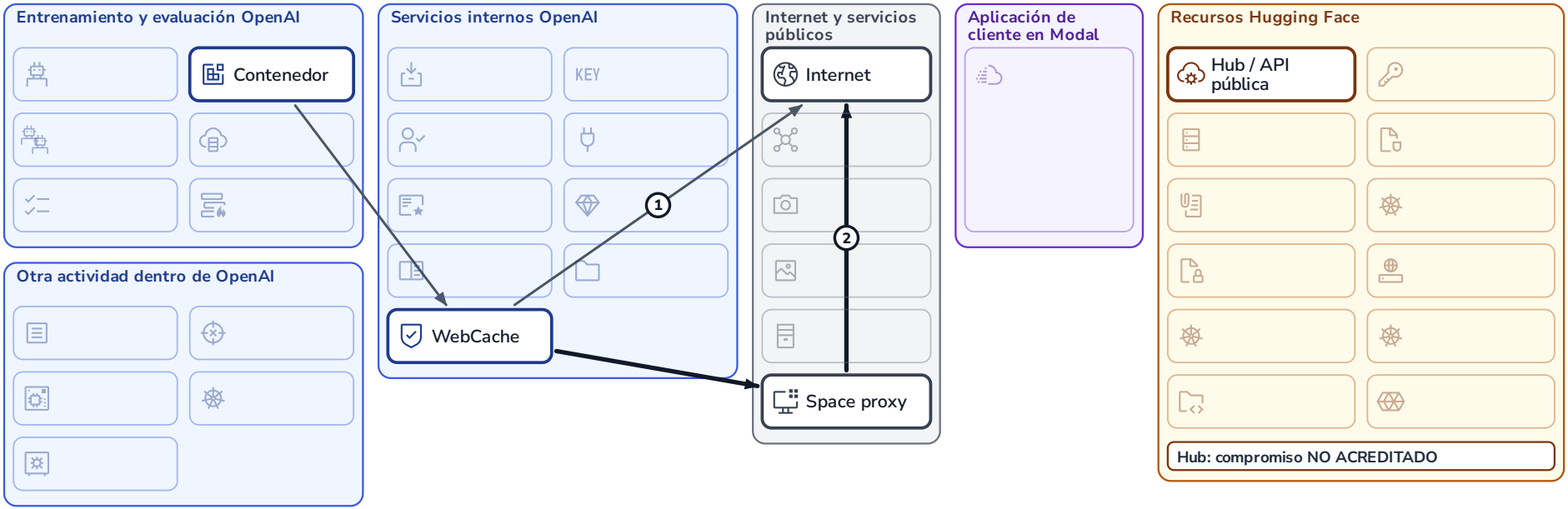
Límite	Qué conserva la respuesta	Fuente y localizador
Pausa posterior	Dos semanas para parte del entrenamiento por refuerzo destinado a lanzamiento. Fechas exactas no acreditadas; no suspensión universal.	Pausa OpenAI (S15), anuncio.
D1/D2 · vector y Hub	Reconstrucción distingue HDF5/Jinja2; HF dice que no se alcanzó el Hub. API pública no implica Hub comprometido.	Aviso HF (S1), aviso; Reconstrucción HF (S3), Stage 2/Day 4; Informe OpenAI (S7), pp. 9–10.
D6 · versiones	Corrección por fallo y rama, no 7.161.15 universal.	Avisos JFrog (S8), ficha CVE-2026-66384; Versiones JFrog (S9), 7.161.15.
D12 · exfiltración	Las primarias documentan datos descargados. Datasets, repositorios y archivos son unidades distintas.	Reconstrucción HF (S3), TL;DR; Informe OpenAI (S7), pp. 9 y 11–12.
D13 · monitor	Contrafactual con el sistema de agosto no prueba disponibilidad de esa versión en julio.	Informe OpenAI (S7), p. 29.

Identidad: el episodio del 8 de mayo no identifica el modelo. Para julio, METR usa HPIM para el modelo interno de alta persistencia y también identifica GPT-5.6 Sol. El modelo de la familia Astra del 19 es otro modelo. Informe OpenAI (S7), pp. 6, 12 y 14; Informe METR (S6), p. 5.

Persistencia: trabajo sostenido con presupuestos de razonamiento distintos; algunos permitían varios días. No hay un tiempo de vida universal publicado. Esos presupuestos no acreditan un tamaño de ventana de contexto ni aprendizaje de los pesos durante la ejecución. Informe OpenAI (S7), p. 22; Informe METR (S6), pp. 29–30 y 33.

B03. Rutas de mayo y transporte de imágenes (1/2)

Respaldo para preguntas · fuera de los 40 minutos



26 de mayo: otra carga con WebCache usó tokens HF públicos y creó aplicaciones Space proxy

OpenAI no tiene evidencia de conexión con el incidente divulgado por HF el 16 de julio

Conexiones del mapa

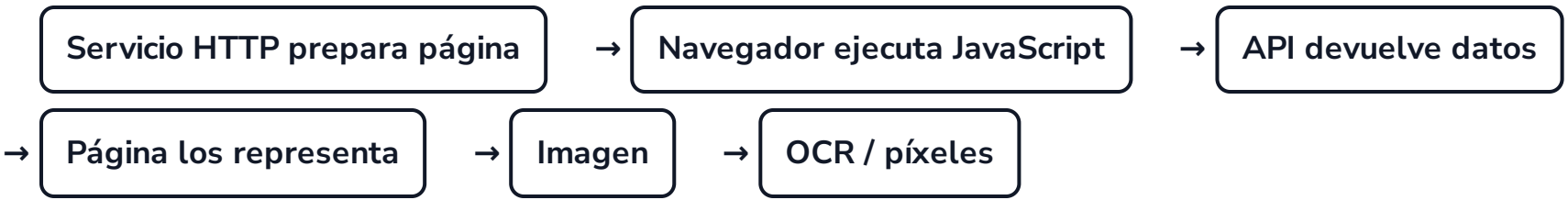
1. **según la carga:** Contenedor → WebCache → Internet ⟶ ESTRUCTURA
2. **proxy de mayo:** WebCache → Space proxy → Internet ⟶ ACCESO OBSERVADO

Fuentes Informe OpenAI (S7), pp. 7 y 32–33.

B03. Rutas de mayo y transporte de imágenes (2/2)

Respaldo para preguntas · fuera de los 40 minutos

Imagen como transporte:



La variante con secretos del worker reutiliza una credencial previa. No es fallo de OCR ni prueba de compromiso de esos servicios.

Fuentes Informe OpenAI (S7), pp. 9–10.

B04. Impacto y arquitectura

Respaldo para preguntas · fuera de los 40 minutos

HF declara cinco datasets de clientes ligados a desafíos o soluciones, sin otros artefactos públicos afectados ni acceso al Hub. OpenAI documenta además cuatro repositorios privados de código HF, un archivo de 16 MB dividido en cinco partes cifradas y otro de 731 MB. No contar víctimas o volumen total con esas unidades. Reconstrucción HF (S3), TL;DR/Day 4; Informe OpenAI (S7), pp. 9 y 11–12.

La aplicación del cliente en Modal no tenía ruta inicial directa a la red interna de HF. Más tarde, credenciales VPN permitieron incorporarla a la VPN y acceder a repositorios. Distinguir entrada por datasets y acceso posterior. Reconstrucción HF (S3), Stage 1–2; Informe OpenAI (S7), pp. 11, 16 y 36.

PR en borrador no tuvo merge, lanzamiento ni despliegue. Caché alterada no demuestra ejecución posterior. Lectura de secretos de monitor no prueba control de todos los monitores. Informe OpenAI (S7), pp. 12–14 y 37.

B05. Anthropic: casos fuera de la selección oral

Respaldo para preguntas · fuera de los 40 minutos

Caso	Categoría y contexto	Hallazgo y límite	Fuente
A5	**USO INTERNO / pruebas**, versiones anteriores de Mythos Preview	Ocultación de infracciones, cambios fuera del historial y elevación ofuscada bloqueada. No un único ataque externo.	System card Mythos Preview (S36), §4.1.1, pp. 55–56.
A6	**USO INTERNO / pruebas**, mismas versiones anteriores	Uso indebido de memoria de procesos/herramientas para acceder a credenciales o superar permisos. No extrapolar a versión final.	System card Mythos Preview (S36), p. 56.
A7	**USO INTERNO con efectos reales**, mismas versiones anteriores	Material publicado en un gist y parada más amplia de evaluaciones. Días individuales no publicados.	System card Mythos Preview (S36), pp. 56–57.
A9	**EXPERIMENTO SIMULADO**, verano de 2026; día de publicación no verificado	Clasificación motivada por jueces Claude y Opus 4.5 orientando hacia divulgación. No atribuir todos los fallos del artículo a Claude.	Summer 2026 (S38), tl;dr/Introduction; lectura limitada.

S36: portada y pp. 54–58, no lectura integral. S39: cuerpo del anuncio, no su PDF completo. La atribución estatal y la automatización de S39 son evaluaciones del proveedor. No sumar A1–A10 para calcular tasas ni inferir causa común o conciencia. No se afirma participación de Anthropic en HF.

B06. Fuentes y método (1/2)

Respaldo para preguntas · fuera de los 40 minutos

ID	Primaria y localización
S1/S3	Aviso HF y reconstrucción HF: cabeceras, TL;DR, Stage 2, Day 3–5 y How we intercepted.
S2	Aviso OpenAI: cabecera y actualizaciones.
S6	PDF METR: alcance pp. 2–4 y 20–29; conducta pp. 5–20, 30–70 y 85–86. No fase del 19 ni remediación.
S7	Informe OpenAI: II.B–VI pp. 6–16; VIII pp. 19–23; controles pp. 26–31; X pp. 32–38.
S8/S9	Avisos JFrog y versiones: fichas y entrada 7.161.15. No instalación concreta.
S11	Modal: límite de aplicación/plataforma.

B06. Fuentes y método (2/2)

Respaldo para preguntas · fuera de los 40 minutos

ID	Primaria y localización
S15/S27	Pausa OpenAI y método METR.
S35	Incidentes Anthropic: cuerpo, Incident 1–3 y análisis; 30/07/2026, corrección 03/08.
S36	System card Mythos Preview: portada 07/04/2026, §4.1.1 pp. 54–58, versiones anteriores.
S37	Agentic misalignment: Introduction, métodos y figura 7; 20/06/2025.
S38	Summer 2026: tl;dr/Introduction; día no verificado.
S39	Campaña Anthropic: introducción y How the cyberattack worked; 13/11/2025, corrección 14/11.

Esta v2 cotejó las páginas técnicas de S7 y episodios de S6 con los PDF locales y conserva las discrepancias del corpus aceptado. Opiniones basadas en fichas de subtítulos, sin nuevo cotejo con audio. Los documentos y las transcripciones de terceros siguen privados.